ESCUELA COLOMBIANA DE INGENIERÍA JULIO GARAVITO

Nombre: Jose Luis Lancheros Ayora

Fecha: 28 de octubre de 2026

Taller: ¿qué vulnerabilidad debemos remediar primero?

Entrega: Tablas de análisis y decisión justificada.

Contexto

Ustedes integran el equipo de seguridad de una universidad. Un análisis identificó cuatro vulnerabilidades distribuidas en tres servicios. Deben recomendar qué remediar primero considerando **CVE, NVD, CVSS, EPSS, exposición, controles e impacto institucional**.

Se estudiarán estos casos:

CVE	Descripción general	Severidad de referencia
CVE-2026-109618	Manejo de memoria insuficiente en PHP que puede ocasionar corrupción de memoria.	9,2 — Crítica
CVE-2026-109619	Uso de estado interno asociado con memoria liberada en PHP.	9,2 — Crítica
CVE-2021-41773	Recorrido de directorios en Apache HTTP Server 2.4.49; las consecuencias dependen de la configuración.	CVSS v3.1: 7,5 — Alta
CVE-2023-44487	HTTP/2 Rapid Reset: agotamiento de recursos que puede provocar denegación de servicio.	CVSS v3.1: 7,5 — Alta

Las puntuaciones son referencias para iniciar la investigación. Verifiquen **fuente, versión y vector** antes de compararlas. Referencias: aviso sobre PHP, valoración de CVE-2021-41773 y valoración de CVE-2023-44487.

Situación de la universidad — caso completamente ficticio

Servicio	Vulnerabilidades y exposición	Impacto y controles
A. Gestión financiera	Afectado por ambos CVE de PHP. Acceso exclusivo mediante VPN, MFA y un grupo limitado de administradores. La restricción de acceso fue verificada.	Contiene datos financieros y bancarios. Tiene segmentación y monitoreo. No se han identificado indicios de compromiso, pero los registros disponibles cubren solo las últimas 24 horas.
B. Archivo de investigación	Apache HTTP Server 2.4.49 afectado por CVE-2021-41773 y expuesto a Internet. Una revisión autorizada confirmó que la configuración permite acceder a archivos fuera del directorio publicado. CGI está deshabilitado.	El servidor almacena investigaciones inéditas y un archivo de configuración con credenciales de una base de datos interna. No hay evidencia confirmada de extracción. No cuenta con WAF.
C. Portal de admisiones	Implementación HTTP/2 afectada por CVE-2023-44487 y expuesta a Internet. El CDN protege el dominio público, pero la dirección del servidor de origen sigue siendo accesible directamente.	Las inscripciones cierran en seis horas. Una interrupción impediría completar solicitudes. Existen picos de CPU y reinicios de conexiones, sin diagnóstico confirmado. No hay un canal alternativo de inscripción.

Restricciones operativas

- Solo hay un equipo disponible para realizar **una corrección permanente durante la primera hora**.
- El personal de redes puede aplicar controles temporales en paralelo.
- En A, actualizar requiere 40 minutos y reiniciar el servicio.
- En B, actualizar requiere 25 minutos; restringir el acceso público requiere 5 minutos.
- En C, actualizar requiere 45 minutos; bloquear el acceso directo al origen requiere 10 minutos. Deshabilitar HTTP/2 es una alternativa temporal cuya compatibilidad debe verificarse.
- Las copias de seguridad están verificadas, pero restaurarlas no revierte una posible filtración.
- Estos tiempos y condiciones son supuestos del ejercicio, no instrucciones para sistemas reales.

Fuentes de consulta

Para cada identificador, consulte su registro en CVE.org y su ficha en NVD.

Consulte EPSS mediante estos enlaces:

- CVE-2026-109618
- CVE-2026-109619
- CVE-2021-41773
- CVE-2023-44487

Use las calculadoras CVSS v3.1 o CVSS v4.0, según corresponda.

Registre las fuentes y fechas. Si falta información, escriba **“no disponible”**. No sustituya los datos ausentes por cero.

1. **¿Qué aporta cada concepto a la decisión?**

Explique la función de CVE, NVD, CVSS y EPSS. Distinga entre identificación, análisis, severidad técnica y probabilidad de explotación. ¿Cuál de estos elementos describe por sí solo el riesgo específico de la universidad?

CVE sirve para identificar. Es un nombre único y público que se le pone a una vulnerabilidad, por ejemplo CVE-2021-41773, y lo asigna una autoridad como PHP, Apache o MITRE. Gracias a ese nombre los escáneres, los proveedores y nosotros hablamos de la misma falla. Lo malo es que el registro CVE solo trae una descripción corta y referencias. No dice qué tan grave es ni si afecta a la universidad. El de CVE-2023-44487, por ejemplo, ni siquiera lista productos.

NVD es la base de datos de NIST y sirve para el análisis. Toma el registro CVE y le agrega más información: su propia puntuación CVSS, el tipo de debilidad, los productos y versiones afectadas en un formato que leen los programas y referencias clasificadas. Ojo que NVD puede ir atrasada o dar un puntaje distinto al del proveedor. Desde abril de 2026 NIST analiza primero los CVE que están en el catálogo KEV de CISA, los de software del gobierno de Estados Unidos y los de software crítico, y a los demás no los analiza de inmediato.

CVSS mide la severidad técnica. Da un número de 0 a 10 y un vector que explica de dónde sale: si se ataca por red, qué tan difícil es, si pide privilegios y cuánto afecta la confidencialidad, la integridad y la disponibilidad. Sirve para comparar qué tan grave es una falla en el peor caso. Su límite es que, según FIRST, mide severidad y no riesgo. No sabe si el servidor está en Internet, qué controles tiene ni si ya la están explotando.

EPSS da la probabilidad de explotación. Es un número entre 0 y 1 que estima qué tan probable es que se vea explotación de ese CVE en los próximos 30 días, y se actualiza todos los días. Sirve para escoger entre muchas vulnerabilidades que se parecen en severidad. Su límite es que habla del CVE en general y no de nuestros servidores, y tampoco dice nada del impacto.

Ninguno de los cuatro describe por sí solo el riesgo de la universidad. Los cuatro hablan de la vulnerabilidad en abstracto: CVE la identifica, NVD la documenta, CVSS dice qué tan grave es y EPSS qué tan probable es que se explote en general. El riesgo nuestro aparece cuando se junta eso con lo local, o sea qué servicio está en Internet y cuál detrás de VPN, qué controles funcionan, qué datos hay y si ya hay señales de compromiso. En este caso se nota, porque los cuatro CVE tienen EPSS casi en 1 y están en KEV, así que eso no ayuda a ordenarlos. Lo que de verdad los separa es la exposición y el impacto de cada servicio.

2. **¿Qué sabemos de las cuatro vulnerabilidades?**

Complete la tabla utilizando CVE, NVD y los avisos del proveedor:

ESCUELA COLOMBIANA DE INGENIERÍA JULIO GARAVITO

CVE	Producto y versiones afectadas	Condiciones necesarias para la explotación	Impacto principal	Solución
CVE-2026-109618	PHP en las versiones anteriores a 8.2.35, 8.3.36, 8.4.27 y 8.5.12. Las ramas 8.1 y anteriores ya no tienen soporte, siguen vulnerables y no van a recibir parche. Google Cloud las cuenta desde la 5.4 y NVD desde la 7.3.0.	Hay que llegar por red al servicio PHP, sin autenticación y sin que el usuario haga nada. El atacante debe lograr que la petición se quede sin memoria mientras PHP todavía está preparando la solicitud, por ejemplo con una petición multipart manipulada, y repetir el intento varias veces. Está probado contra Apache con mod_php y por el análisis del código también afectaría a FPM y FrankenPHP. La complejidad es alta.	Ejecución remota de código con los permisos del proceso web, o sea confidencialidad, integridad y disponibilidad en alto. También se puede filtrar memoria.	Actualizar a 8.2.35, 8.3.36, 8.4.27 o 8.5.12, o a una más nueva de la misma rama, y reiniciar los procesos de PHP. Si se usa 8.1 o menos hay que cambiar de versión. Los ajustes de php.ini solo ayudan en parte.
CVE-2026-109619	Las mismas versiones y ramas que el CVE anterior. NVD y Google Cloud lo cuentan desde la 5.4.	También por red y sin autenticación. Una petición deja datos internos apuntando a memoria que ya se liberó, por un error fatal o por falta de memoria, y otra petición atendida por el mismo proceso los usa antes de que se reinicien, por ejemplo con avisos de configuración o con session.upload_progress. Hay que acertar cómo queda la memoria, por eso la complejidad es alta. Está probado con mod_php y con FPM.	Uso de memoria liberada que lleva a ejecución remota de código y filtración de memoria, con los permisos del proceso web.	La misma actualización y reiniciar los procesos. El aviso dice que no existe una configuración que lo arregle por completo. Solo ayudan en parte cosas como poner session.upload_progress.enabled en 0.
CVE-2021-41773	Apache HTTP Server 2.4.49 solamente. Las versiones anteriores no están afectadas. La 2.4.50 trae un arreglo incompleto y por eso existe CVE-2021-42013.	El servidor debe ser alcanzable por el atacante y tener archivos fuera de las carpetas con alias que no estén protegidos con Require all denied. Eso ya se confirmó en el servicio B. No necesita autenticación. Para ejecutar código tendría que haber además CGI habilitado en esas rutas.	Lectura de archivos fuera de la carpeta publicada, como código, configuración y credenciales, o sea confidencialidad. Con CGI habilitado también ejecución remota de código.	Actualizar a Apache 2.4.51 o más nueva, porque la 2.4.50 no basta. Revisar que la raíz siga con Require all denied. En Linux instalar el paquete corregido de la distribución.
CVE-2023-44487	No disponible en el registro CVE, que pone el producto como n/a. Es una falla del protocolo HTTP/2 y cada implementación la corrige por aparte. NVD lista 304 coincidencias de productos, por ejemplo nghttp2 antes de 1.57.0, Go antes de 1.20.10 o de 1.21.3 según la rama, Netty antes de 4.1.100 y Caddy antes de 2.7.5. El caso no dice qué implementación usa el servicio C.	HTTP/2 activo y alcanzable por el atacante. En el servicio C es el servidor de origen, al que se puede entrar directo sin pasar por el CDN. No necesita autenticación. El cliente abre muchos streams y los cancela enseguida con RST_STREAM, así nunca pasa el límite de streams a la vez y casi no le cuesta nada.	Denegación de servicio por agotamiento de recursos. Solo afecta la disponibilidad.	Actualizar la implementación de HTTP/2 a la versión corregida de su fabricante. Limitar o cerrar las conexiones que cancelan muchos streams y proteger con CDN, balanceador o WAF. Desactivar HTTP/2 sirve solo como medida temporal y hay que probar la compatibilidad.

Identifique una diferencia entre el registro CVE y la información disponible en NVD. Para el servicio B, explique cómo influye que CGI esté deshabilitado, sin descartar la exposición de archivos ya confirmada.

Una diferencia que encontré es con CVE-2026-109618. El registro de CVE.org, que publicó PHP, trae solo la puntuación CVSS v4.0 de 9,2 y las cuatro ramas corregidas, de la 8.2 a la 8.5. NVD agrega su propia puntuación CVSS v3.1, que es de 9,8, y en CVE-2026-109619 es de 8,1. También agrega una lista de productos con un rango de versiones más amplio, desde PHP 7.3.0 y en el otro CVE desde 5.4.0, e incluye productos de otros fabricantes que el registro CVE no menciona, como Palo Alto PAN-OS y Panorama y Siemens RUGGEDCOM APE1808. Por eso un escáner basado en NVD y el registro CVE pueden no coincidir en qué está afectado, y toca revisar el aviso del proveedor. Con CVE-2021-41773 pasa algo parecido, porque en CVE.org solo aparece el 7,5 que agregó CISA y NVD publica 9,8 como puntuación principal.

Sobre el servicio B y el CGI deshabilitado. La ejecución remota de código de CVE-2021-41773 depende de que haya CGI habilitado en las rutas con alias, según el registro CVE y Apache. Como en B el CGI está deshabilitado, esa vía no existe y el peor caso, el 9,8 de NVD, no aplica. El impacto queda en confidencialidad, que es lo que dice el vector de 7,5 de CISA y de Amazon. Pero eso no quita la exposición que ya se confirmó. La configuración deja leer archivos fuera de la carpeta publicada, desde Internet, sin autenticación y sin WAF, y en ese servidor hay investigaciones sin publicar y un archivo con credenciales de una base de datos interna. El atacante no necesita ejecutar código para hacer daño, le basta con leer ese archivo. Y que no haya evidencia confirmada de extracción no quiere decir que no haya pasado. Y el CVE está en KEV y CISA lo marca con explotación activa y automatizable. Entonces el CGI apagado baja el impacto máximo pero no baja la urgencia de B. Aparte de actualizar, hay que cambiar esas credenciales y revisar los registros. También conviene comprobar en la configuración que de verdad no haya CGI.

3. ¿Qué nos dice CVSS y cuáles son sus límites?

Registre para cada CVE la fuente, versión, puntuación y vector completo. Reproduzca en la calculadora el vector de uno de los CVE de 7,5 y explique dos métricas.

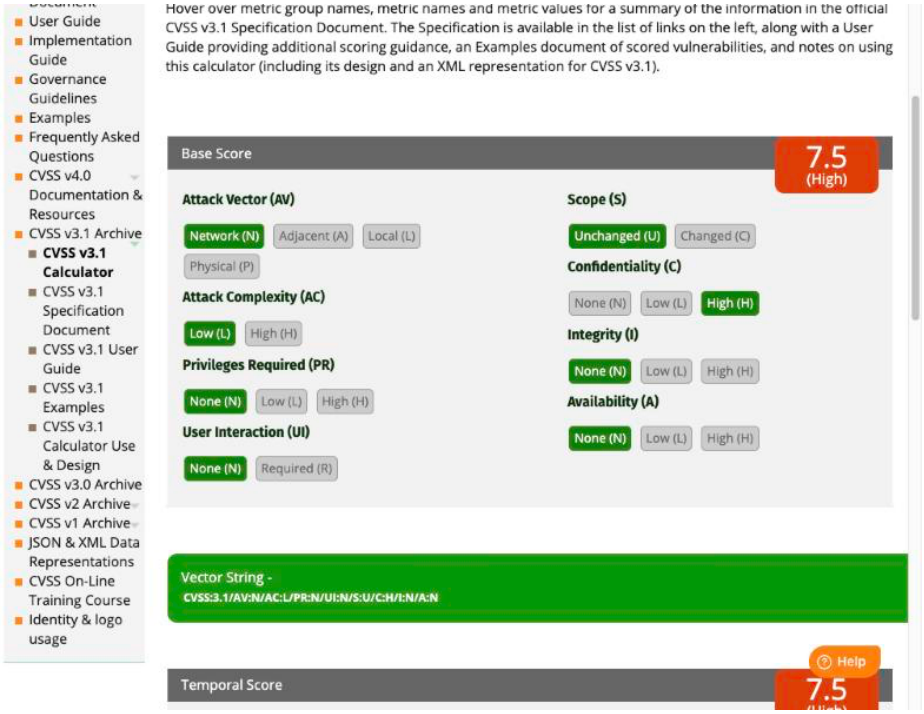
Estas son las puntuaciones que encontré para cada CVE, con la fuente, la versión de CVSS y el vector completo.

CVE	Fuente	Versión	Puntuación	Vector completo
CVE-2026-109618	PHP, que es la CNA, publicado en CVE.org y en el aviso GHSA	4.0	9,2 Crítica	CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
CVE-2026-109618	NVD de NIST, puntuación principal	3.1	9,8 Crítica	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVE-2026-109619	PHP, que es la CNA, publicado en CVE.org y en el aviso GHSA	4.0	9,2 Crítica	CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
CVE-2026-109619	NVD de NIST, puntuación principal	3.1	8,1 Alta	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H
CVE-2021-41773	CISA ADP, que aparece en CVE.org y en NVD, y Amazon Linux	3.1	7,5 Alta	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CVE-2021-41773	NVD de NIST, puntuación principal	3.1	9,8 Crítica	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVE-2021-41773	NVD de NIST, versión antigua	2.0	4,3 Media	AV:N/AC:M/Au:N/C:P/I:N/A:N

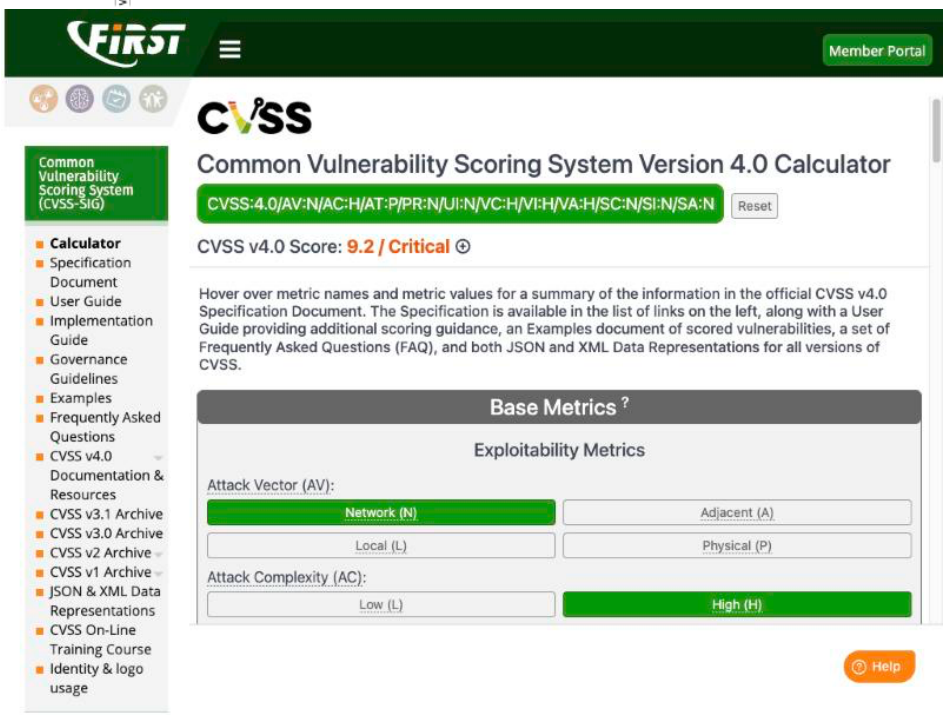
CVE	Fuente	Versión	Puntuación	Vector completo
CVE-2023-44487	NVD de NIST, CISA ADP y Amazon Linux	3.1	7,5 Alta	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Comprobé los 9,2 con la calculadora oficial de CVSS v4.0 y los 9,8, 8,1 y 7,5 de v3.1 con la fórmula de la especificación, y todos coinciden. Los 9,2 de PHP son solo de la parte Base, o sea que no incluyen amenaza ni entorno.

Reproduje en la calculadora oficial de FIRST para CVSS v3.1 el vector de CVE-2021-41773 que publican CISA y Amazon Linux, que es CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N. La calculadora dio una puntuación base de 7,5 High, como se ve en la captura. También lo calculé a mano con la fórmula de la especificación. El subpuntaje ISS da 0,56 porque solo la confidencialidad está en alto. El impacto es 6,42 por 0,56, que da 3,5952. La explotabilidad es 8,22 por 0,85 por 0,77 por 0,85 por 0,85, que da 3,8870. Se suman, queda 7,4822, y al redondear hacia arriba da 7,5.



Captura de la calculadora de FIRST para CVSS v3.1 con el vector de CVE-2021-41773. Resultado: 7,5 High.



Captura de la calculadora de FIRST para CVSS v4.0 con el vector de los dos CVE de PHP. Resultado: 9,2 Critical.

AV:N quiere decir vector de ataque por red. El componente vulnerable se puede alcanzar a través de la red y los atacantes posibles llegan hasta todo Internet, por eso se dice que es explotable remotamente. Es el valor con más peso en la explotabilidad, 0,85. En el servicio B importa porque el servidor está publicado en Internet y cualquiera puede intentarlo.

C:H quiere decir confidencialidad alta. Es cuando se pierde toda la confidencialidad del componente, o cuando se obtiene información restringida cuya divulgación es grave, como la contraseña de un administrador. En B encaja porque ahí hay investigaciones sin publicar y un archivo con credenciales de una base de datos. Es la única métrica de impacto en alto, porque I y A están en N. Si se supone ejecución de código por CGI, I y A pasan a H y la puntuación sube a 9,8, que es la que publica NVD.

Responda: ¿por qué una vulnerabilidad de 7,5 podría requerir atención antes que una de 9,2? Si las puntuaciones utilizan versiones diferentes de CVSS, ¿qué precaución debe tener al compararlas?

Porque la puntuación base de CVSS mide qué tan grave es la falla técnicamente y no cuánto riesgo hay para nosotros. FIRST lo dice en sus documentos y aclara que no debe usarse sola para priorizar parches. CVSS no sabe qué tan expuesto está el servicio, qué controles tiene ni si ya la están explotando. En este caso lo veo así. El 9,2 de PHP necesita condiciones difíciles, que son AC:H y AT:P, y el servicio A solo se alcanza por VPN con MFA y con un grupo pequeño de administradores. El 7,5 de Apache es muy fácil de explotar porque tiene AC:L, PR:N y UI:N, el servicio B está en Internet, la configuración vulnerable ya se confirmó, no tiene WAF y detrás hay investigaciones sin publicar y credenciales. CISA marca ese CVE con explotación activa y automatizable, y los de PHP con explotación activa pero no automatizable. Por último, el 7,5 de HTTP/2 solo afecta la disponibilidad, pero en el servicio C eso significa perder una inscripción de seis horas sin otro canal. Entonces la urgencia sale de qué tan probable es que pase y de cuánto daño haría en este entorno, no del número.

Hay que tener cuidado porque CVSS v4.0 no es solo una versión más precisa de la v3.1. Agrega la métrica de requisitos de ataque, AT, quita el alcance y lo cambia por el impacto en el sistema vulnerable y en los

sistemas que vienen después, y calcula la puntuación con conjuntos de equivalencia ordenados por expertos y no con la fórmula de la v3.x. Por eso un 9,2 de v4.0 no es más grave que un 7,5 de v3.1 en el mismo sentido. Lo que haría es comparar solo puntuaciones de la misma versión y de la misma fuente, o comparar los vectores métrica por métrica, y siempre anotar fuente, versión y vector.

Los datos del taller lo muestran. La misma falla de PHP tiene 9,2 en v4.0 y 9,8 o 8,1 en v3.1, y en v3.1 las dos de PHP se distinguen por AC:L y AC:H, pero en v4.0 quedan iguales. CVE-2021-41773 tiene 9,8 y 7,5 en la misma versión, según se suponga o no que hay CGI, y 4,3 en la versión 2.0. Otra precaución es verificar los números de v4.0 con la calculadora, porque NIST reconoció en abril de 2026 que unos 4.500 registros de NVD, el 19 % de los que tenían v4.0, traían un número mal calculado. Yo recalculé el 9,2 y sí da.

4. ¿Cómo cambia el análisis al incorporar EPSS? — 10 minutos

Consulte los cuatro valores para una misma fecha y complete:

CVE	Fecha del dato	EPSS entre 0 y 1	Probabilidad en %	Percentil
CVE-2026-109618	28/10/2026	0,99999	99,999 %	0,99998
CVE-2026-109619	28/10/2026	0,99999	99,999 %	0,99999
CVE-2021-41773	28/10/2026	0,99992	99,992 %	0,99986
CVE-2023-44487	28/10/2026	0,99999	99,999 %	0,99998

Los valores salen de la API de EPSS de FIRST, que consulté el 28 de octubre de 2026 a las 5:38 p. m., hora de Colombia. La API devolvió la misma fecha para los cuatro CVE.

Explique qué significa la probabilidad de explotación durante los próximos 30 días y en qué se diferencia del percentil. ¿Por qué EPSS no representa la probabilidad exacta de compromiso de cada servidor de la universidad? ¿Un EPSS bajo descarta los indicios locales?

La probabilidad a 30 días es un número entre 0 y 1 que dice qué tan probable es que se vea explotación de ese CVE en los próximos 30 días. Más exacto, que algún socio de datos de EPSS detecte y reporte actividad de explotación. Está calibrada, o sea que entre muchos CVE con 0,05 se espera ver explotación en unos 5 de cada 100. El percentil es otra cosa, es una posición relativa. Un CVE en el percentil 90 tiene un EPSS más alto que el 90 % de los CVE puntuados. Como casi todos los CVE tienen valores cerca de cero, una probabilidad de 0,10 ya queda cerca del percentil 95. Entonces la probabilidad responde qué tan probable es y el percentil responde qué tan arriba está en el ranking. En estos cuatro CVE coinciden porque todos están en el tope.

EPSS no es la probabilidad exacta de que nos comprometan un servidor por varias razones. Primero, es una estimación global por CVE basada en la explotación que ven los sensores de sus socios. No mide compromisos exitosos ni lo que pasa en nuestros servidores. Segundo, FIRST aclara que no mide cuánto daño haría la explotación ni si afecta a nuestro entorno, y que no tiene en cuenta los controles que ya hay. Un PHP detrás de VPN con MFA, como el servicio A, y un Apache expuesto sin WAF, como el B, tienen puntajes igual de altos aunque su probabilidad real de compromiso es muy distinta. Tercero, cambia todos los días. CVE-2026-109618 pasó de 0,118 el 24 de octubre a 0,9998 el 25 de octubre.

Un EPSS bajo no descarta los indicios locales. EPSS es una expectativa sobre todos los CVE y los indicios locales son observaciones directas de nuestros sistemas, como los picos de CPU y los reinicios de conexión

del servicio C, la configuración vulnerable que ya se confirmó en B o una cuenta VPN comprometida en A. EPSS solo ve lo que detectan los sensores de sus socios, y un ataque dirigido o contra sistemas internos puede no aparecer. Un valor bajo quiere decir poca explotación esperada en general, no que no estemos comprometidos. Y uno alto tampoco prueba que lo estemos.

En este caso los cuatro CVE están en el tope, desde 0,99992 hasta 0,99999, y todos están en KEV. Por eso EPSS no sirve para ordenarlos entre sí, y para decidir me apoyo en la exposición, el impacto y los controles de cada servicio.

5. ¿Qué debe remediarse primero? — 15 minutos

Construya una matriz y asigne prioridad a los tres servicios:

Servicio	Severidad CVSS	EPSS de los CVE aplicables	Exposición y condiciones de explotación	Impacto institucional	Eficacia de los controles	Prioridad justificada
A	9,2 en v4.0 para los dos CVE. En v3.1 de NVD son 9,8 y 8,1. Si se explota, el impacto técnico es total.	0,99999 y 0,99999. Los dos están en KEV desde el 26 de octubre.	No está en Internet. Solo se entra por VPN con MFA y un grupo limitado de administradores, y eso se verificó. Para explotar hay que llegar al servicio y cumplir condiciones difíciles, AC:H y AT:P. CISA lo marca como no automatizable.	Muy alto. Hay datos financieros y bancarios, y el atacante ejecutaría código con los permisos del proceso web.	Buenos. Hay VPN con MFA verificada, segmentación y monitoreo. Pero si una cuenta VPN se compromete el control deja de servir, y los registros de solo 24 horas no permiten descartar un compromiso anterior.	Segunda, alta. Es la segunda corrección permanente y desde ya se guardan sus registros.
B	7,5 en v3.1 según CISA y Amazon, que solo toca la confidencialidad y encaja con que el CGI esté apagado. NVD pone 9,8 porque supone ejecución de código con CGI.	0,99992, igual durante los últimos 30 días. Está en KEV desde 2021 y CISA lo marca con uso conocido en ransomware.	Está en Internet, la configuración vulnerable ya se confirmó, no pide autenticación ni interacción y no tiene WAF. La explotación es automatizable y hay exploits públicos. El CGI apagado cierra la ejecución de código pero no la lectura de archivos.	Alto y no se puede devolver. Hay investigaciones sin publicar y un archivo con credenciales de una base de datos interna, que podría servir para moverse a otros sistemas. Restaurar copias no deshace una filtración.	Hoy ninguno sirve. No hay WAF y la propia configuración permite el acceso.	Primera, crítica. Es el único servicio con exposición pública confirmada, explotación muy fácil y daño que no se puede revertir, y es el más barato de corregir, 25 minutos. Coincide con el ejemplo de CISA del plazo más corto, tres días con análisis forense: activo expuesto, automatizable e impacto técnico total.
C	7,5 en v3.1 según NVD, CISA y Amazon. Solo afecta la	0,99999, igual durante los últimos 30 días. Está en KEV	Está en Internet. El CDN protege el dominio pero al servidor de origen se puede entrar directo y	Alto pero limitado. Solo afecta la disponibilidad, durante seis horas y sin otro canal de	Parciales. El CDN sirve para el dominio pero no cubre el origen. Bloquear el acceso	Tercera para la corrección permanente, pero con control temporal

	disponibilidad, A:H.	desde octubre de 2023.	así se salta esa protección. No pide autenticación. Ya hay picos de CPU y reinicios de conexión sin diagnóstico, así que podría haber un ataque en curso.	inscripción. Una solicitud que se pierda no se recupera.	directo al origen toma 10 minutos y arregla eso sin afectar a los usuarios.	inmediato. Sube a segunda si los picos de CPU siguen después del bloqueo.

Mi decisión es que el equipo de parches empiece por el servicio B y que redes proteja B y C al mismo tiempo. El equipo de parches es el recurso escaso, entonces lo pongo donde el daño posible es mayor y no se puede devolver, la explotación es muy fácil y la corrección es barata. La restricción temporal de B deja el archivo fuera de servicio para el público, y solo el parche permite abrirlo otra vez. Redes cubre lo que se puede aislar sin parchear. A queda de segundo porque su control de acceso está verificado y no hay otro control temporal para agregar, solo el parche lo reduce más. C queda de tercero porque su control temporal funciona bien y no afecta a los usuarios, y porque su riesgo se acaba cuando cierran las inscripciones, mientras que el de A sigue.

Presente un plan que indique:

a. Qué corrección permanente realizará el equipo durante la primera hora.

El equipo de parches se dedica al servicio B. Actualiza Apache a 2.4.51 o a una versión más nueva, lo que toma 25 minutos, y revisa que se mantenga Require all denied y que el CGI siga apagado. Después la misma revisión autorizada que encontró el problema repite su prueba, y se cambian las credenciales de la base de datos. Calculo unos 15 minutos para eso, pero es un supuesto mío porque el enunciado no da ese tiempo. Cuando B queda cerrado el equipo sigue con A.

b. Qué controles temporales aplicará redes en paralelo y cómo verificará su eficacia.

Redes restringe el acceso público a B, que toma 5 minutos, y lo mantiene hasta cerrar B. Para verificarlo, desde una red externa la conexión tiene que fallar, desde la red permitida tiene que responder, el registro de Apache no debe recibir más direcciones externas y la revisión autorizada repite su prueba desde afuera y ya no debe llegar.

También bloquea el acceso directo al origen de C, que toma 10 minutos, dejando entrar solo a las direcciones del CDN. Para verificarlo, una conexión directa a la IP del origen desde afuera tiene que fallar, por el dominio público el portal tiene que responder y una inscripción de prueba tiene que completarse, y el origen solo debe ver direcciones del CDN. También se comparan la CPU, las conexiones, los reinicios de conexión y los errores 5xx quince minutos antes y quince minutos después. Si no bajan, los picos no venían solo del acceso directo, así que se investiga, se evalúa desactivar HTTP/2 después de revisar la compatibilidad y C pasa a ser el segundo en parchearse.

Mientras tanto, el personal de monitoreo exporta y guarda los registros de A, que solo duran 24 horas, los de Apache de B y los de C, del origen y del CDN.

c. Qué servicio atenderá después y qué riesgo quedará pendiente.

Sigue A, que toma 40 minutos y un reinicio. Antes de reiniciar se exportan los registros y se buscan señales de ataque que publicó Google, como cookies PHPSESSID muy largas, procesos hijos del servidor web como sh, bash o curl, y reinicios con SIGSEGV. Si aparece alguna se captura la

memoria de los procesos antes de reiniciar, porque reiniciar borra esa evidencia. Después viene C, que toma 45 minutos, con un plan de reversión listo porque las copias están verificadas y antes de que cierren las inscripciones. Si actualizar pone en riesgo el servicio, se deja para cuando cierren y mientras tanto se mantiene el bloqueo del origen.

El riesgo que queda al terminar la primera hora es el de A, porque alguien con acceso a la VPN podría ejecutar código y con registros de 24 horas no se puede descartar un compromiso anterior. Y el de C, porque el ataque Rapid Reset podría llegar por otra vía distinta al origen bloqueado y todavía no se sabe qué causa los picos.

d. Qué evidencia permitirá cerrar cada hallazgo.

Para B: la versión 2.4.51 o más nueva comprobada en el servidor y el registro del cambio, una prueba autorizada a rutas fuera de la carpeta publicada que devuelva 403 o 404, Require all denied activo y sin módulos CGI cargados, la credencial anterior revocada y sin inicios de sesión sospechosos en la base de datos, y la revisión de los registros documentada.

Para A: la versión corregida de su rama, que es 8.2.35, 8.3.36, 8.4.27 u 8.5.12, el proceso reiniciado después de actualizar, los registros revisados y la restricción de la VPN comprobada desde afuera.

Para C: el acceso directo al origen bloqueado con una prueba externa, la implementación de HTTP/2 actualizada o desactivada y documentada, las métricas en su nivel normal durante varias horas, el diagnóstico de los picos documentado y el flujo de inscripción probado de principio a fin.

e. Si corresponde investigar una posible exposición de credenciales o un incidente de disponibilidad.

Sí, las dos cosas. En B hay que tratar las credenciales como posiblemente expuestas, porque que no haya evidencia de extracción no significa que no hubo. Se buscan en los registros rutas fuera de la carpeta publicada, como las que traen %2e o dos puntos seguidos, y accesos al archivo de configuración, y se revisan los inicios de sesión de la base de datos con esa credencial. En C hay que investigar un posible incidente de disponibilidad, o sea saber si los picos son Rapid Reset, carga normal u otra cosa, comparando los registros del origen con los del CDN. Con A también se hace una revisión con las 24 horas de registros que hay.

Justifique por qué su decisión supera una clasificación basada únicamente en CVSS o únicamente en EPSS. **No multiplique ambos valores como si el resultado fuera una medida validada de riesgo.**

Si solo uso CVSS, A con 9,2 iría de primera y el único equipo de parches se iría a un servicio con acceso restringido que ya se verificó, mientras B esperaría estando en Internet, con la configuración vulnerable confirmada, uso conocido en ransomware y credenciales detrás. Si solo uso EPSS, los cuatro están entre 0,99992 y 0,99999, o sea empatan, y una diferencia de 0,00007 en el tope del modelo no ordena nada. Y EPSS no dice nada del impacto ni de la exposición.

Lo que decide es la exposición, los controles, el valor de lo que hay en el servicio, si el daño se puede devolver, el plazo y cuántos minutos le toma al equipo. Eso se parece a lo que usa la directiva BOD 26-04 de CISA, que decide con cuatro preguntas: si el activo está expuesto, si está en KEV, si la explotación es automatizable y si el impacto técnico es parcial o total. No usa puntuaciones CVSS ni EPSS. Esa directiva solo obliga a agencias federales de Estados Unidos, así que yo la uso solo como referencia. No multipliqué CVSS por EPSS porque eso no es una medida de riesgo validada. Son datos de cosas distintas, la severidad técnica y la probabilidad general de explotación.

6. ¿Qué evidencia modificaría su decisión? — 5 minutos

Durante la intervención se confirma que una cuenta VPN de administrador del servicio A fue comprometida y utilizada desde una ubicación inusual. Todavía no se ha confirmado explotación de PHP.

¿Cambiaría su orden de atención? Explique qué acciones realizaría de inmediato, cómo afectaría esta evidencia a su interpretación de EPSS y si mantendría o modificaría los controles previstos para B y C.

Sí cambia el orden de atención, pero no el orden de los parches, que sigue siendo B, A y C. A pasa a ser un incidente en curso y su respuesta empieza de una vez, al mismo tiempo que el parche de B. El parche de A va justo después, antes que C. La razón es que el control que me hizo dejar a A en segundo lugar, la VPN con MFA verificada, ya no es confiable porque hay una credencial de administrador usada desde una ubicación inusual. Las fallas de PHP, que están en KEV, no necesitan autenticación y tienen impacto total, quedan al alcance de quien use esa credencial.

Lo que haría de inmediato es esto. Primero guardar la evidencia sin alertar al atacante, o sea copiar fuera del servidor los registros de la VPN, de autenticación y de A, ampliar el tiempo que se guardan y anotar qué se recogió, de dónde, cuándo y quién. La guía de CISA dice que contener antes de recoger evidencia puede destruirla y avisarle al atacante. Segundo, contener todo en una sola acción: deshabilitar la cuenta y no solo cambiar la clave, cerrar sus sesiones de VPN, revocar tokens y volver a registrar su MFA, bloquear el origen inusual y buscar otras cuentas que hayan entrado desde la misma IP. Tercero, revisar qué hizo esa cuenta, o sea si entró a A, B, C o a la base de datos, si dejó algo para volver a entrar y si hay señales de explotación de PHP. Cuarto, dejar el acceso a A en un grupo mínimo y desde un equipo de salto, y cambiar las credenciales y el MFA de todos los administradores. Quinto, actualizar A, que toma 40 minutos y un reinicio, con A aislado y después de capturar la memoria de los procesos si hay señales de ataque. Si el servidor está comprometido se reconstruye desde una copia anterior al incidente, y como las copias no deshacen una filtración, también habría que evaluar si toca notificar.

Sobre EPSS, el número no cambia, porque 0,99999 describe el CVE y no nuestro servidor. Lo que cambia es cuánto aplica a A. Antes el acceso restringido separaba a A de esa probabilidad, y ahora hay evidencia de que esa barrera se pudo saltar. Con esto me queda claro que la evidencia local pesa más que el valor global, porque aunque el EPSS fuera bajo haríamos lo mismo. Y que todavía no se haya confirmado explotación de PHP no quiere decir que no haya pasado, porque EPSS y KEV no ven nuestros registros y A solo guarda 24 horas.

Los controles de B y C los mantendría, con un ajuste. Revisaría que el rango de la VPN no esté entre las excepciones de B ni de C. Si está, lo cerraría y dejaría solo un equipo de salto, porque quien tenga VPN podría llegar a B y C desde adentro y saltarse esos controles. B gana urgencia porque guarda credenciales de una base de datos interna, por eso su parche y el cambio de credenciales siguen primero. Si se confirma explotación de PHP en A o movimiento hacia B o C, A pasa a incidente mayor, se aísla, B y C se tratan como posiblemente comprometidos y se rehace el orden según lo que se encuentre.

7. ¿Cómo defendería su recomendación? — 5 minutos

Redacte una conclusión de máximo **120 palabras** para el director de tecnología. Indique la primera corrección permanente, las mitigaciones simultáneas, el riesgo residual y la principal incertidumbre.

Recomiendo corregir primero el servicio B, actualizando Apache a la 2.4.51 o más nueva en 25 minutos. Es el único expuesto a Internet con vulnerabilidad confirmada, explotación fácil, uso en ransomware y credenciales internas guardadas. Por eso va antes que A, que tiene CVSS de 9,2 pero está protegido por

VPN con MFA. Al mismo tiempo redes restringe el acceso público a B y bloquea el acceso directo al origen de C, y se guardan los registros de A. Después se actualizan A y C. Quedan el riesgo de ejecución remota de código en A y de un ataque a C. La incertidumbre principal es si hubo accesos no autorizados antes, porque los registros no lo descartan.

La evaluación considerará la precisión de las fuentes, la interpretación de CVSS y EPSS y la coherencia de la decisión. **No existe un orden obligatorio: la recomendación debe reducir el riesgo del caso y sostenerse con evidencia.**

Fuentes consultadas

CVE.org, registros de CVE-2026-109618, CVE-2026-109619, CVE-2021-41773 y CVE-2023-44487. https://www.cve.org. Consultados el 28 de octubre de 2026.

NVD, fichas de los cuatro CVE. https://nvd.nist.gov. Consultadas el 28 de octubre de 2026. También los avisos de NIST del 15 y del 28 de abril de 2026 sobre cómo prioriza NVD y sobre puntuaciones CVSS v4 incorrectas, en https://www.nist.gov/itl/nvd.

PHP, avisos de seguridad GHSA-w8hw-w9fx-j79w y GHSA-6wmf-4rv5-p3rp en https://github.com/php/php-src/security/advisories y versiones 8.2.35, 8.3.36, 8.4.27 y 8.5.12 en https://www.php.net/releases. Todo del 21 de octubre de 2026.

Google Cloud, Responding to core PHP vulnerabilities CVE-2026-109618 and CVE-2026-109619. Publicado el 21 de octubre de 2026 y actualizado el 23 de octubre. https://cloud.google.com/blog/products/identity-security/responding-to-core-php-vulnerabilities-cve-2026-109618-cve-2026-109619/

CISA, alerta sobre las vulnerabilidades de PHP, revisada el 26 de octubre de 2026. https://www.cisa.gov/news-events/alerts/2026/10/21/critical-vulnerabilities-php-require-immediate-patching

Apache HTTP Server, página de vulnerabilidades de la versión 2.4. https://httpd.apache.org/security/vulnerabilities_24.html. Consultada el 28 de octubre de 2026.

Amazon Linux Security Center, CVE-2021-41773 y CVE-2023-44487. https://explore.alas.aws.amazon.com. Consultados el 28 de octubre de 2026.

Google Cloud, How it works: The novel HTTP/2 Rapid Reset DDoS attack. Publicado el 10 de octubre de 2023. https://cloud.google.com/blog/products/identity-security/how-it-works-the-novel-http2-rapid-reset-ddos-attack

FIRST, calculadoras de CVSS v3.1 y v4.0, especificación v3.1, guía de usuario y preguntas frecuentes de v4.0. https://www.first.org/cvss. Consultados el 28 de octubre de 2026.

FIRST, EPSS, con la API en https://api.first.org/data/v1/epss y las preguntas frecuentes en https://www.first.org/epss/faq. Datos del 28 de octubre de 2026.

CISA, catálogo de vulnerabilidades explotadas conocidas, KEV, versión 2026.10.28. https://www.cisa.gov/known-exploited-vulnerabilities-catalog

CISA, directiva BOD 26-04 del 10 de junio de 2026 y su guía de implementación. https://www.cisa.gov/news-events/directives/bod-26-04-prioritizing-security-updates-based-risk